ROOMIA PLATFORM

AUDITORÍA TÉCNICA & ASEGURAMIENTO DE CALIDAD DE SOFTWARE

Folio: AUD-2026-V3.1
Norma: ISO/IEC 25010

INFORME TÉCNICO DE HALLAZGOS Y REMEDIACIONES DE AUDITORÍA

Proyecto: ROOMIA PLATFORM — Plataforma de Hospitalidad & Residencias Arquitectónicas

Código de Auditoría: AUD-ROOMIA-2026-V3.1

Estándares de Referencia: ISO/IEC 25010 · OWASP Top 10 · PCI-DSS 4.0 · LFPDPPP / SAT (México)

Fecha de Emisión: 10 de Noviembre de 2026

Clasificación: Documento Oficial de Auditoría de Sistemas y Seguridad

---

1. Resumen Ejecutivo de la Auditoría

Se realizó una auditoría integral de código fuente, arquitectura de software, concurrencia transaccional, esquema de base de datos y controles de seguridad sobre el proyecto **Roomia**.

Estado General de Hallazgos

Severidad	Identificados Inicialmente	Remediados y Verificados	Pendientes
CRÍTICA	3	3	0
ALTA	3	3	0
MEDIA	2	2	0
BAJA	1	1	0
TOTAL	**9**	**9**	**0**

Dictamen: **100% DE LOS HALLAZGOS HAN SIDO REMEDIADOS Y VERIFICADOS CON PRUEBAS AUTOMATIZADAS**.

---

2. Matriz Detallada de Hallazgos y Remediaciones

Hallazgo H-01: Exposición de Consola Administrativa en el Bundle Público

- **Severidad**: CRÍTICA (CWE-284: Improper Access Control)

- **Condición Inicial**: El portal de usuarios compartía el mismo árbol de rutas con la administración. Cualquier visitante podía teclear `/admin` o `/admin/login` en la barra del navegador y acceder a la interfaz de backoffice en el mismo puerto y host.
- **Riesgo**: Exposición de vectores de ataque de fuerza bruta contra cuentas de administradores, robo de credenciales y fuga de información estructural.
- **Remediación Implementada**:

1. Se implementó la segregación física multi-aplicación inspirada en el estándar de Carmela Balón.

2. En el portal público (`frontend`, puerto `5174`), se eliminaron totalmente las rutas `/admin`. Cualquier intento de acceso responde con un componente formal `404 - Página no encontrada` (`NotFoundPage.tsx`).

3. Se construyó una aplicación completamente independiente (`frontend-admin`, puerto `5175`) aislada de los clientes, protegida por el guardia de rutas `AdminRoute.tsx`.

- **Estado**: `RESUELTO` / `VERIFICADO`.

Hallazgo H-02: Condición de Carrera y Riesgo de Doble Reserva (Double-Booking)

- **Severidad**: `CRÍTICA` (CWE-362: Race Condition / Concurrency Control)
- **Condición Inicial**: Las validaciones de fechas se efectuaban en memoria o sin bloqueos transaccionales a nivel de fila, permitiendo que peticiones simultáneas sobre la misma propiedad en las mismas fechas confirmaran dos reservas distintas.
- **Riesgo**: Sobreventa de residencias, incumplimiento contractual, pérdida de reputación y penalizaciones financieras.
- **Remediación Implementada**:

1. Implementación del patrón de bloqueo pesimista `SELECT ... FOR UPDATE` en el motor de base de datos (`backend/apiEngine.mjs`).

2. Cuando una reserva entra en proceso de confirmación, las fechas del inmueble quedan bloqueadas a nivel atómico en la tabla `locked_dates`.

3. La primera petición concurrente concluye exitosamente (`HTTP 201 Created`), mientras que cualquier intento simultáneo superpuesto es rechazado de inmediato con `HTTP 409 Conflict`.

- **Estado**: `RESUELTO` / `VERIFICADO` **(Prueba CP-CONC-01** `PASS` **)**.

Hallazgo H-03: Almacenamiento Inseguro de Credenciales y Falta de Bloqueo por Fuerza Bruta

- **Severidad**: `CRÍTICA` (CWE-307 / CWE-916: Weak Password Hashing & Brute Force)
- **Condición Inicial**: Uso de algoritmos de hash criptográficamente insuficientes o ausencia de parámetros de memoria y tiempo contra ataques paralelos con GPU/ASIC.
- **Riesgo**: Compromiso masivo de contraseñas ante una fuga de base de datos o ataques de diccionario por fuerza bruta.

- **Remediación Implementada**:

1. Adopción del algoritmo **Argon2id** con configuración recomendada por OWASP: `memoryCost=65536` (64 MB), `timeCost=4` iteraciones, `parallelism=2` hilos (`backend/apiEngine.mjs`).

2. Sanitización estricta de DTOs: la propiedad `passwordHash` se elimina en el servidor antes de serializar respuestas JSON.

3. Mecanismo de defensa activa: Bloqueo de cuenta tras **5 intentos fallidos consecutivos**, respondiendo con `HTTP 429 Too Many Requests` .

- **Estado**: RESUELTO / VERIFICADO **(Pruebas CP-AUTH-01 y CP-AUTH-02** PASS **)**.

Hallazgo H-04: Ausencia de Pistas de Auditoría Inmutables y No Repudio

- **Severidad**: ALTA (CWE-778: Insufficient Logging / ISO/IEC 25010)
- **Condición Inicial**: No existía un registro de transacciones que garantizara que un administrador con privilegios elevados no pudiera modificar o borrar registros históricos de pagos o reservas.
- **Riesgo**: Modificación fraudulenta de estados financieros o de reservas sin posibilidad de detección forense.
- **Remediación Implementada**:

1. Creación de la tabla `audit_logs` con encadenamiento criptográfico continuo SHA-256 (`backend/schema.sql`). Cada evento calcula:

$$\text{current_hash} = \text{SHA256}(\text{previous_hash} \parallel \text{event_type} \parallel \text{payload} \parallel \text{timestamp})$$

2. Trigger PL/pgSQL a nivel de motor de datos que intercepta y bloquea cualquier instrucción `UPDATE` o `DELETE` sobre la bitácora, arrojando una excepción `SQLSTATE 45000: Modificación no autorizada en bitácora inmutable` .

- **Estado**: RESUELTO / VERIFICADO **(Pruebas CP-AUD-01 y CP-AUD-02** PASS **)**.

Hallazgo H-05: Incumplimiento del Estándar PCI-DSS 4.0 en el Flujo de Pago

- **Severidad**: ALTA (PCI-DSS 4.0 Requisito 3: Protección de Datos de Tarjetahabiente)
- **Condición Inicial**: Existía la posibilidad de que formularios de pago capturaran datos PAN (número completo de tarjeta) o CVV en servidores de la aplicación.
- **Riesgo**: Multas de marcas de tarjetas (Visa, Mastercard), pérdida de licencia comercial de procesamiento y robo de identidad financiera.
- **Remediación Implementada**:

1. Implementación de arquitectura **Zero-PAN Storage**: Ningún dato de tarjeta se almacena en las bases de datos de Roomia (`frontend/src/components/public/PaymentGatewayModal.tsx`).

2. Tokenización en cliente y verificación 3D Secure 2.0.

3. Validación de webhooks de pago mediante firmas criptográficas `HMAC-SHA256`: peticiones forjadas o manipuladas son rechazadas con `HTTP 400 Bad Request`.

4. Precisión de cálculo financiero forzada en tipo `NUMERIC(10,2)` (Subtotal + 12% Comisión + 16% IVA).

- **Estado**: RESUELTO / VERIFICADO **(Pruebas CP-CONC-02, CPF-02 y CP-INT-04 PASS)**.

Hallazgo H-06: Falta de Validación Sintáctica Estricta y Coordenadas Geográficas

- **Severidad**: ALTA (CWE-20: Improper Input Validation / RFC 5322)
- **Condición Inicial**: Correos electrónicos con caracteres de inyección o formatos no canónicos eran aceptados sin validar sintaxis estricta RFC 5322. Del mismo modo, propiedades podían registrarse fuera del territorio permitido.
- **Riesgo**: Inyecciones de encabezados (Header Injection) y datos geográficos espurios en el catálogo.
- **Remediación Implementada**:

1. Expresión regular canónica RFC 5322 en el motor backend (`backend/apiEngine.mjs`): correos inválidos retornan `HTTP 422 Unprocessable Entity`.

2. Delimitación de cuadrante geográfico estricto para residencias (`Latitud: 18.8 a 19.7`, `Longitud: -100.3 a -99.0`): coordenadas fuera de rango son rechazadas con `HTTP 422`.

- **Estado**: RESUELTO / VERIFICADO **(Pruebas CPF-01 y CP-CAT-01 PASS)**.

Hallazgo H-07: Publicación de Reseñas no Verificadas (Fake Reviews)

- **Severidad**: MEDIA (CWE-285: Improper Authorization)
- **Condición Inicial**: Cualquier usuario podía emitir calificaciones sobre una residencia sin haber completado una estancia real.
- **Riesgo**: Manipulación artificial del catálogo y fraude comercial a los usuarios.
- **Remediación Implementada**:

1. Verificación obligatoria en backend: Sólo se permite insertar una reseña si existe una reservación asociada con estado `COMPLETED` a nombre de ese huésped (`backend/apiEngine.mjs`).

2. Intentos no verificados son rechazados con `HTTP 403 Forbidden`.

- **Estado**: RESUELTO / VERIFICADO **(Pruebas CPF-05 y CP-REV-01 PASS)**.

Hallazgo H-08: Deficiencia en la Experiencia Cartográfica (Marcas de Agua y Falta de Pines)

- **Severidad**: MEDIA (Usabilidad & Integridad Geoespacial)
- **Condición Inicial**: Mosaicos cartográficos de terceros bloqueados con marcas de agua (`API KEY REQUIRED`) o iframe estático que sólo mostraba un punto genérico sin listar las residencias.

- **Riesgo**: Inoperabilidad de la navegación geográfica para el usuario final.
- **Remediación Implementada**:

1. Sustitución por capas de OpenStreetMap (100% libres y sin claves) y Esri Satelital HD (`InteractiveMapView.tsx`).

2. Las 10 residencias georreferenciadas con pines de precio interactivos, paneo automático y enlaces directos a Google Maps Oficial y Waze Rutas en Vivo.

- **Estado**: RESUELTO / VERIFICADO.

Hallazgo H-09: Ausencia de Mecanismos de Facturación SAT CFDI 4.0 y Derechos ARCO

- **Severidad**: **BAJA / REGULATORIA** (Cumplimiento SAT y LFPDPPP)
- **Condición Inicial**: La plataforma no permitía facturación deducible mexicana ni contaba con centro legal público para derechos ARCO.
- **Riesgo**: Pérdida de clientes corporativos y riesgo de apercibimiento por parte del INAI.
- **Remediación Implementada**:

1. Módulo completo de facturación fiscal SAT CFDI 4.0 (`SatInvoicingModal.tsx`) con generación de UUID, Sello Digital y descarga de XML y PDF.

2. Creación del Centro Legal en `/legal` (`LegalNoticePage.tsx`) con Aviso de Privacidad Integral bajo LFPDPPP y procedimiento formal para derechos ARCO.

- **Estado**: RESUELTO / VERIFICADO.
